

Information Security Policy

Persistence

Owner: Founder (acting Security Lead) · **Contact:** support@persistence.finance

Version: 1.0 · **Effective:** 2026-06-16 · **Review cadence:** at least annually, and after any material change

1. Purpose & scope

This policy defines how Persistence protects the confidentiality, integrity, and availability of the data it handles — in particular **consumer financial data** obtained through Plaid. It applies to all Persistence systems (web app, desktop app, API, database), the people who operate them, and the third parties that process data on our behalf.

2. Roles & responsibilities

Persistence is operated by a small team. The **Founder serves as the Security Lead** and is accountable for information security, vendor risk, incident response, and periodic review of this policy. Security issues are received at **support@persistence.finance** and via GitHub security advisories.

3. Data classification

- **Highly sensitive:** Plaid access tokens, account balances and transactions, authentication secrets (JWT signing keys, API keys), the data-encryption key.
- **Sensitive:** user identity (email, Google profile), goals/bills/settings.
- **Operational:** application logs, error/diagnostic data.

Bank login credentials are **never** received or stored — authentication happens inside Plaid's secure flow.

4. Access control

- **Least privilege:** production access (Railway, Vercel, GitHub, Plaid, Google Cloud) is limited to authorized personnel only.
- **Unique accounts & MFA:** each administrator uses a unique account; multi-factor authentication is required on all accounts that can access production systems or consumer financial data.
- **End-user authentication:** users authenticate (Google OAuth or email+password) before any account linking. Sessions use short-lived access tokens (15 min) with rotating refresh tokens.
- The production database is not publicly exposed; access is via credentialed connections only.

5. Encryption

- **In transit:** all connections (web, desktop, API) use TLS 1.2+ / HTTPS. No unencrypted endpoints.
- **At rest:** data resides in a managed PostgreSQL database with disk-level encryption at rest.
- **Application-level:** Plaid access tokens are additionally encrypted with **AES-256-GCM** before storage, so database access alone does not expose a usable token.

- **Passwords:** stored only as bcrypt hashes (Google sign-in handles no password at all).
- **Desktop:** the desktop app stores session credentials in the OS keychain (Windows Credential Manager), not in plaintext files.

6. Secrets management

Secrets (database URL, JWT signing key, Plaid/Google/Anthropic/Stripe keys, the data-encryption key) are stored as environment variables in the hosting provider's secret store — **never** committed to source control. Updater/release artifacts are cryptographically signed.

7. Third-party / vendor management

Data is shared only with subprocessors necessary to run the product: **Plaid** (bank connectivity), **Anthropic** (optional AI features; commercial terms — data not used for model training), **Stripe** (payments), **Resend** (transactional email), **Sentry** (error monitoring), and **Railway/Vercel** (hosting). **Google** is involved only for Google sign-in. We do not sell user data.

8. Vulnerability & patch management

- **Dependency scanning:** GitHub Dependabot alerts and automated security updates are enabled across all packages (npm, Cargo, GitHub Actions).
- **Patching:** OS/infrastructure patching is handled by the managed hosting providers (Railway, Vercel).
- **Code review** is performed before changes are deployed; desktop releases are signed and signature-verified before install.

9. Logging & monitoring

Application errors are captured via Sentry (when enabled); the API is rate-limited, authenticated on every request, and served with hardened security headers (Helmet). Anomalous bank-connection states trigger user-facing re-authentication alerts.

10. Incident response

Suspected incidents are triaged by the Security Lead following the runbook in *docs/incident-response.md*: contain, assess scope, remediate, rotate any exposed secrets, and notify affected users and partners (including Plaid) as required. Vulnerabilities may be reported responsibly to support@persistence.finance or via GitHub security advisories.

11. Data retention & deletion

Users can export all their data and permanently delete their account in-app; deletion removes personal and financial data and revokes bank connections at Plaid. Retention is described in the public Privacy Policy (<https://persistence.finance/privacy.html>). Backups cycle out on a rolling basis.

12. Change & configuration management

All code is version-controlled in Git. Changes are reviewed before deployment to production. Infrastructure configuration and secrets are managed through the hosting providers' consoles by authorized personnel only.

13. Acceptable use & endpoint security

Personnel access production only from up-to-date, password/biometric-protected devices with disk encryption and reputable anti-malware enabled, and must not store production secrets in plaintext or share accounts.

14. Policy review

This policy is reviewed by the Security Lead at least annually and after any material change to systems, data flows, or processors. Public-facing security and privacy commitments are maintained at <https://persistence.finance/security.html> and <https://persistence.finance/privacy.html>.